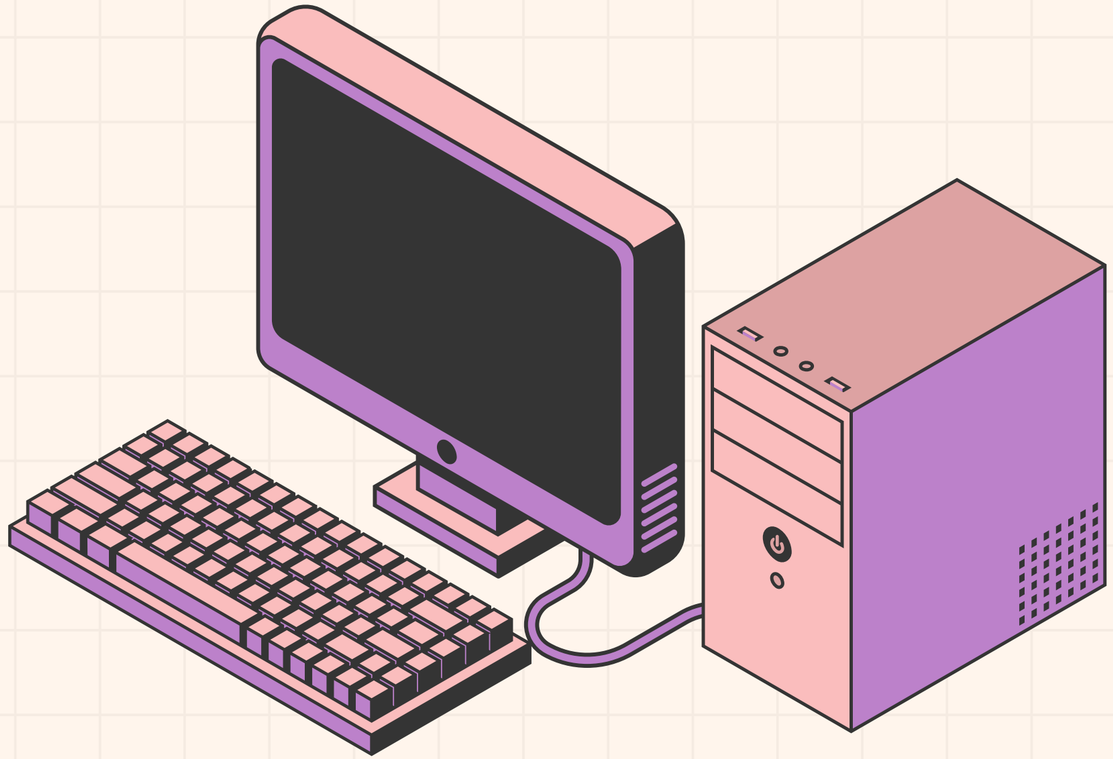
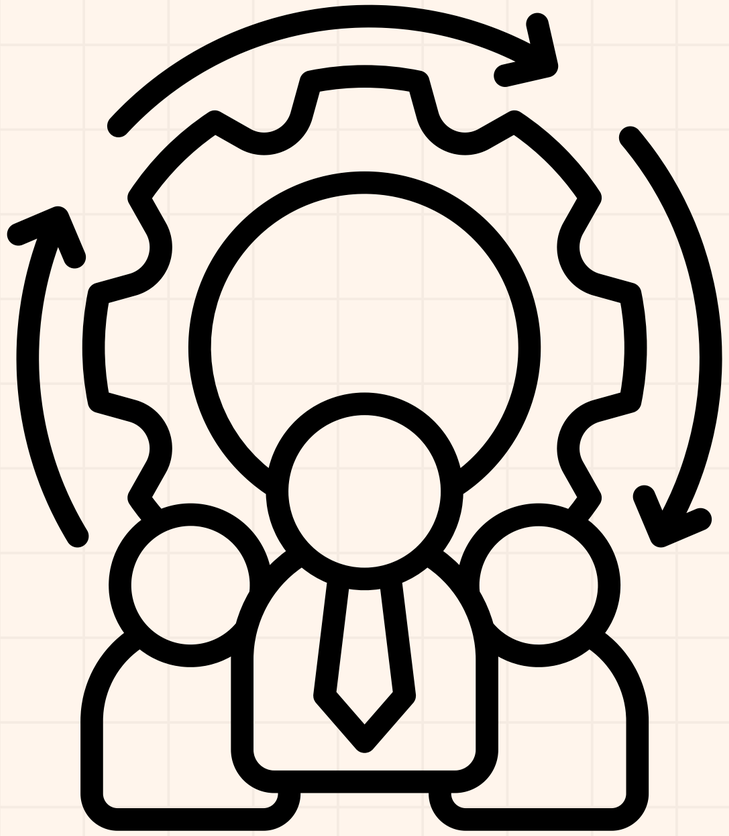
PLANEACIÓN, CONTROL Y CIERRE

Criptografía y Seguridad



DE LA PERCEPCIÓN A LA EVIDENCIA

Un proyecto no se controla preguntando si "todo va bien" o asumiendo un "60% de avance" sin pruebas verificables de entregables terminados y aceptados.



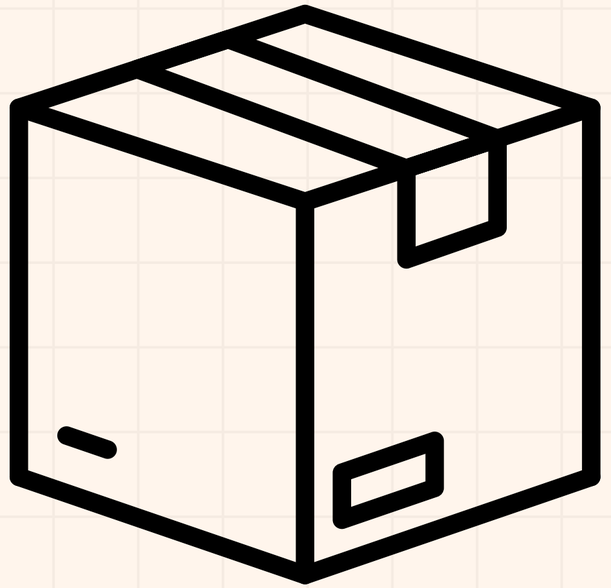
ESTRUCTURA DE DESGLOSE (EDT/WBS)

La Estructura de Desglose del Trabajo (EDT), o Work Breakdown Structure (WBS), organiza jerárquicamente el trabajo necesario para producir los resultados del proyecto.

- Descomposición Jerárquica: Divide entregables complejos en componentes manejables y medibles. La unidad minima se llama **Paquete de Trabajo**
- Regla del 100%: La EDT contiene el 100% del trabajo acordado en el alcance, ni más ni menos.

EL PAQUETE DE TRABAJO

Es el nivel más bajo de la EDT que permite estimar, asignar responsabilidades y supervisar. Permite responder con precisión:

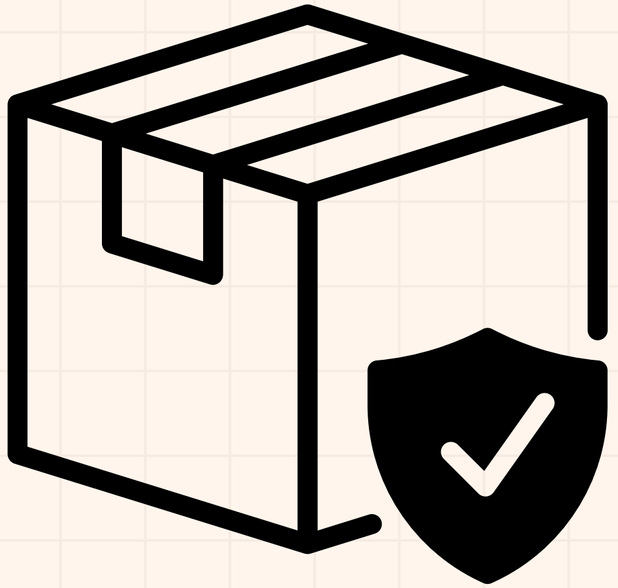


- ¿Quién es el responsable técnico?
- ¿Cuánto tiempo y esfuerzo requiere?
- ¿Cómo verificamos que está terminado?

SEGURIDAD EXPLÍCITA EN LA EDT

La seguridad no ocurre por accidente, si las actividades de seguridad no están explícitamente en la EDT, no tendrán presupuesto ni tiempo asignado.

Algunos ejemplos de Paquetes de trabajo pensados para garantizar seguridad pueden ser: Modelado de amenazas, revisiones de código seguro (SAST/DAST), hardening de servidores y pruebas de penetración previas a producción.



EJEMPLO

Para poner un ejemplo concreto, tomaremos de ejemplo la tarea de crear un sistema de autentificacion academico. asi pues, al desglosarlo podemos generar los siguientes paquetes de trabajo:

- Inicio de Sesión y Políticas de Contraseñas (Login Core)
- Autenticación Multi-Factor (MFA / 2FA)
- Recuperación Segura de Cuentas (Self-Service Reset)
- Control de Acceso y Gestión de Sesiones (RBAC & Sessions)
- Registro de Eventos y Auditoría de Seguridad (Logging/SIEM)
- Pruebas de Seguridad y Verificación de Autenticación

INICIO DE SESIÓN Y POLÍTICAS DE CONTRASEÑAS

Implementación de la interfaz de autenticación web/API, validación de credenciales y almacenamiento seguro.

- Almacenamiento con algoritmos criptográficos robustos con "salt" (“Argon2id” o “bcrypt”).
- Validación de complejidad y longitud mínima de contraseñas contra listas de contraseñas comprometidas (NIST SP 800-63B).
- Mecanismo de Rate Limiting y bloqueo temporal ante ataques de fuerza bruta y credential stuffing.

Para validar este paquete se debe superar lo siguiente: 0 contraseñas en texto claro en base de datos; bloqueo activo tras 5 intentos fallidos consecutivos.

AUTENTICACIÓN MULTI-FACTOR (MFA)

Mecanismo de doble factor obligatorio para perfiles administrativos y docentes, y opcional/recomendado para alumnos.

- Integración de protocolo TOTP (Google Authenticator, Microsoft Authenticator) o llaves de seguridad FIDO2/WebAuthn.
- Generación y almacenamiento cifrado de códigos de respaldo (*backup codes*) de un solo uso.

Para validar este paquete se debe superar lo siguiente: Verificación obligatoria del segundo factor al iniciar sesión con rol administrativo; revocación segura de dispositivos vinculados.

RECUPERACIÓN SEGURA DE CUENTAS

Flujo de autoservicio para restablecimiento de contraseña olvidada.

- Respuestas genéricas en formulario para evitar la “enumeración de usuarios” (User Enumeration)
- Generación de tokens criptográficamente seguros, de un solo uso y con tiempo de vida corto (máx. 15 minutos).
- Notificación automática por canal alterno (correo institucional) ante solicitud de restablecimiento.

Para validar este paquete se debe superar lo siguiente: El enlace de recuperación expira tras el primer uso o transcurridos 15 minutos; no revela si un correo existe o no en el sistema.

CONTROL DE ACCESO Y GESTIÓN DE SESIONES (RBAC)

Manejo de sesiones activas, tokens de autorización y matriz de roles y permisos.

- Cookies de sesión protegidas con banderas “HttpOnly”, “Secure” y “SameSite=Strict”
- Expiración por inactividad (30 min) y cierre de sesión global (“Single SignOut”).
- Validación de permisos en el backend (“Principle of Least Privilege”), no solo en la interfaz gráfica.

Para validar este paquete se debe superar lo siguiente: Imposibilidad de acceder a rutas privilegiadas manipulando identificadores de sesión (protección IDOR)

AUDITORÍA Y MONITOREO DE SEGURIDAD (LOGS)

Sistema de recolección de eventos críticos de acceso e integración con la infraestructura de monitoreo.

- Formato estándar de logs (timestamp UTC, IP origen, User-Agent, tipo de evento, resultado).
- Prohibición estricta de registrar contraseñas, tokens o PII en texto claro en los archivos de log.
- Alertas automáticas ante anomalías (múltiples inicios de sesión concurrentes desde ubicaciones geográficas distantes).

Para validar este paquete se debe superar lo siguiente: Los logs se envían de forma inmutable al servidor Syslog/SIEM y no contienen credenciales sensibles.

PRUEBAS DE SEGURIDAD Y HARDENING DEL MÓDULO

Verificación técnica previa al despliegue para validar la resistencia del módulo frente a ataques comunes.

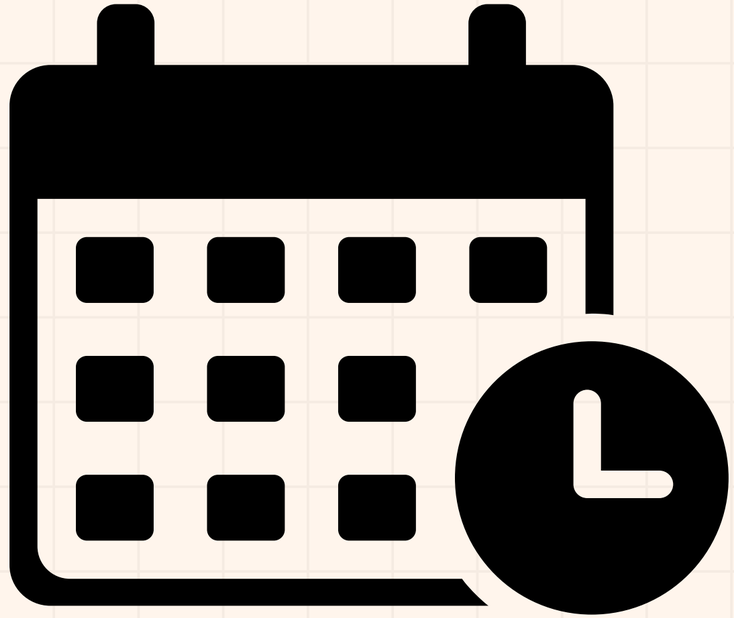
- Escaneo SAST (análisis estático de código) y DAST enfocado en OWASP Top 10 (A01: Broken Access Control, A07: Identification and Authentication Failures).
- Pruebas de omisión de autenticación (*Authentication Bypass*).

Para validar este paquete se debe superar lo siguiente: Dictamen técnico que certifique cero vulnerabilidades críticas o altas abiertas en el módulo de autenticación.

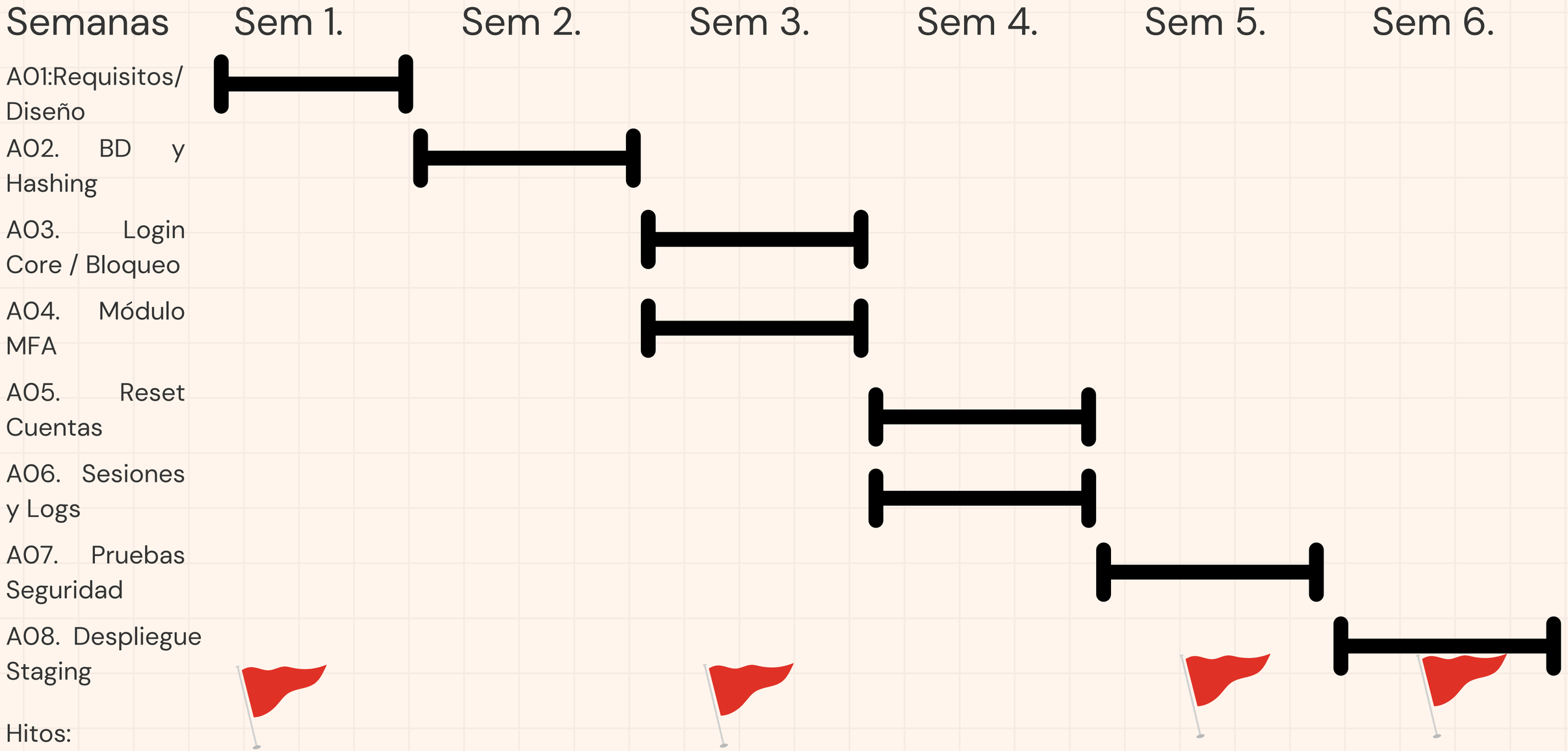
CRONOGRAMA Y DEPENDENCIAS

Ahora que ya sabemos como se desglosa el trabajo para un proyecto, debemos administrar el tiempo que requiere cada paquete de trabajo, para esto se usaran los cronogramas.

Un cronograma es una representación temporal del trabajo del proyecto, indicando actividades, duración, secuencia, dependencias y fechas relevantes.



EJEMPLO


Semanas
Sem 1.
Sem 2.
Sem 3.
Sem 4.
Sem 5.
Sem 6.
A01:Requisitos/ Diseño
A02. BD y Hashing
A03. Login Core / Bloqueo
A04. Módulo MFA
A05. Reset Cuentas
A06. Sesiones y Logs
A07. Pruebas Seguridad
A08. Despliegue Staging
Hitos:

¿TERMINADO O ACEPTADO?

Aunque se usan como sinonimos, estas palabras se refieren a cosas distintas:

- **"Terminado" (Equipo):** El equipo técnico finalizó la codificación o configuración y cree haber concluido su parte.
- Sin criterios objetivos, un módulo inseguro o incompleto puede declararse "listo".

- **"Aceptado" (Validador):** La autoridad designada (Product Owner, CISO) verifica el cumplimiento de los criterios de aceptación.
- MFA obligatorio verificado en pruebas UAT.
- Evidencia de logs de auditoría inmutables.

GESTION DE CAMBIOS

Los cambios son naturales en proyectos de TI, pero incorporarlos sin análisis genera fracasos por Scope Creep. Para evitar esto, se debe seguir un flujo de trabajo especifico para añadir dicho cambio.

- **Flujo de aprobación**

Solicitud

→ Descripción

→ Análisis de Impacto

→ Decisión de la Autoridad

→ Ajuste de Línea Base

→ Implementación

TRANSICIÓN A OPERACIÓN Y CIERRE

El proyecto no finaliza con el código; debe transferirse formalmente a la operación continua, para lograr esto se deben realizar acciones como:

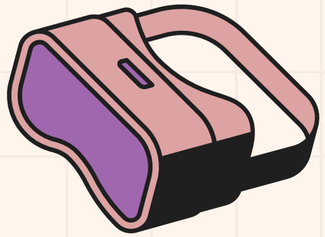
- Entrega de manuales técnicos y guías de respuesta a incidentes.
- Transferencia de credenciales maestras y custodia de llaves criptográficas.
- Configuración de alertas en el SOC / SIEM institucional.

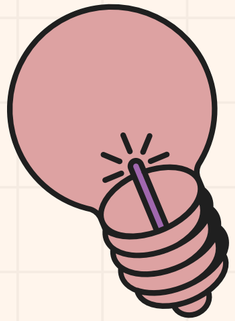
una ves terminado el proyecto, lo ideal seria hacer una revisión honesta del desempeño: ¿Qué estimaciones fallaron?, ¿Qué controles de seguridad funcionaron mejor? y ¿Qué prácticas deben estandarizarse para proyectos futuros?

ACTIVIDAD: ORDENAR EL PROYECTO

- A.-Capacitar usuarios.
- B.-Obtener requisitos.
- C.-Desplegar.
- D.-Diseñar arquitectura.
- E.-Migrar datos.
- F.-Desarrollar.
- G.-Probar.
- H.-Configurar infraestructura.

1. ¿Cuál debe ocurrir primero?, ¿Cuáles pueden ser paralelas? ¿Qué dependencias existen? ¿Dónde agregarían pruebas de seguridad?





GRACIAS

